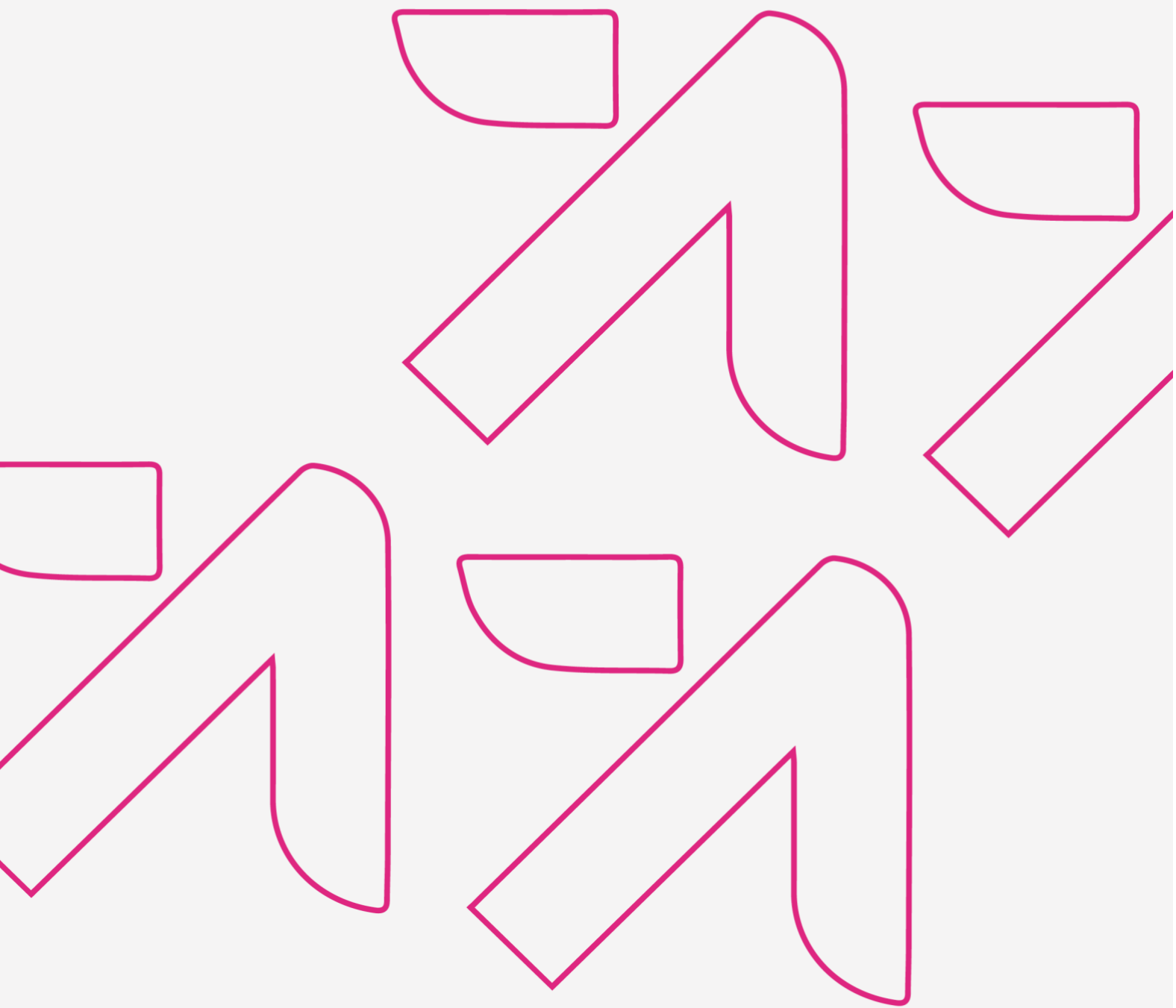




Máster de

Ciberseguridad Hacking Ético

[Módulo Bastionado de Redes y Sistemas]

Curso académico 2026/2027 - Edición Presencial

UT4. Bastionado de servicios críticos

Encaje en el curso 2026/2027: esta unidad desarrolla el RA7 (temas 12 y 13: servicios, protocolos y administración remota segura) y enlaza con el RA5 (tema 10).

1. Objetivo del bastionado de servicios

El propósito del bastionado de servicios es asegurar que todos los servicios expuestos (o internos) estén configurados con las mínimas funcionalidades necesarias, protegidos con cifrado fuerte, autenticación adecuada y sin configuraciones débiles que permitan ataques triviales.

Los servicios mal configurados son una de las principales causas de intrusiones.

2. Principios generales de bastionado de servicios

2.1. Mínima funcionalidad

El servicio debe hacer exactamente lo necesario y nada más. Opciones, módulos y extensiones innecesarias se deshabilitan.

2.2. Cifrado obligatorio

Todo tráfico sensible debe ir cifrado mediante TLS con configuraciones modernas.

2.3. Autenticación y control de acceso

Nunca se deja acceso libre cuando el servicio ofrece mecanismos de autenticación.

2.4. Reducción de superficie

Limitar puertos, restricciones por IP, límites de conexión, timeouts y políticas defensivas.

2.5. Registro y monitorización

Cada servicio crítico debe registrar actividad y enviar logs a un sistema centralizado.

3. Bastionado de servicios web (HTTP/HTTPS)

3.1. Deshabilitar HTTP

Redirigir siempre a HTTPS. No hay excepciones.

3.2. TLS seguro

- Mínimo TLS 1.2; ideal TLS 1.3.
- Deshabilitar cifrados débiles (RC4, DES, 3DES, CBC vulnerables).
- Usar certificados válidos y renovarlos de forma automática (protocolo ACME, por ejemplo con Let's Encrypt y certbot).

3.3. Configuración del servidor web

- En Nginx/Apache deshabilitar módulos innecesarios.
- Limitar “server tokens” para no revelar versión.
- Proteger headers:
 - HSTS
 - X-Content-Type-Options
 - X-Frame-Options (o la directiva frame-ancestors de CSP, que la sustituye)
 - Content-Security-Policy
 - Referrer-Policy y Permissions-Policy

```
# Nginx: fragmento de un servidor bastionado
server_tokens off;
ssl_protocols TLSv1.2 TLSv1.3;
add_header Strict-Transport-Security "max-age=31536000" always;
add_header X-Content-Type-Options "nosniff" always;
add_header Content-Security-Policy "default-src 'self'; frame-ancestors 'none'"
always;
client_max_body_size 2m;
```

El resultado se comprueba desde fuera con `curl -I https://servidor` o con herramientas como `testssl.sh`.

3.4. Protección frente a ataques comunes

- Limitar tamaño de peticiones.
- Configurar rate limiting.
- Aislar el servidor web de la base de datos.
- Usar reverse proxy para aislar aplicaciones.

4. Bastionado del servicio SSH

4.1. Configuraciones esenciales

- Deshabilitar login de root.
- Permitir solo claves públicas, no contraseñas.
- Limitar SSH a usuarios específicos.
- Restringir por IP con AllowUsers y firewall.

4.2. Seguridad adicional

- Fail2ban o equivalentes para evitar fuerza bruta.
- Usar puertos no estándar solo como medida anti-ruído.
- Mantener OpenSSH actualizado y limitar los algoritmos a los modernos. El protocolo SSH1 ya no existe en las versiones actuales, así que hoy el riesgo está en los cifrados y claves antiguos (RSA corto, DSA, SHA-1).

```
# /etc/ssh/sshd_config.d/90-hardening.conf
PermitRootLogin no
PasswordAuthentication no
PubkeyAuthentication yes
AllowUsers admin1 admin2
MaxAuthTries 3
LoginGraceTime 30
X11Forwarding no
ClientAliveInterval 300
ClientAliveCountMax 2
```

Antes de recargar el servicio, valida la sintaxis con `sudo sshd -t` y deja abierta la sesión actual hasta comprobar que puedes entrar con una nueva.

5. Bastionado de RDP (Windows)

5.1. Endurecimiento básico

- Activar Network Level Authentication (NLA).
- Exigir TLS.
- Restringir RDP solo a direcciones concretas.
- No exponer RDP directamente a Internet: publicarlo siempre a través de VPN o de RD Gateway, con MFA.

5.2. Reglas de firewall

Permitir únicamente tráfico RDP desde redes o jump servers autorizados.

5.3. Supervisión

- Registrar conexiones exitosas y fallidas.
- Alertas por múltiples intentos fallidos o accesos fuera de horario.

6. Bastionado de DNS

6.1. Configuración segura

- No permitir recursión en servidores públicos.
- Separar DNS interno del externo.
- Limitar transfers de zona solo a servidores autorizados.

6.2. Protección

- Habilitar DNSSEC si la infraestructura lo soporta.
- Ocultar la versión del servidor y limitar la tasa de respuestas (RRL) para no servir de amplificador en ataques DDoS.
- Registrar consultas y peticiones malformadas.

7. Bastionado de bases de datos (MySQL, PostgreSQL, SQL Server)

7.1. Principios esenciales

- Nunca dejar la base de datos expuesta a Internet. Debe escuchar solo en la interfaz que necesita (bind-address en MySQL/MariaDB, listen_addresses en PostgreSQL).
- Acceso solo desde servidores autorizados (web, API).
- Usuarios con permisos mínimos para cada aplicación.

7.2. Configuraciones críticas

- Deshabilitar cuentas por defecto.
- Rotación periódica de contraseñas o claves.
- Cifrar conexiones cliente-servidor.
- Separar roles de administración y aplicación.

7.3. Supervisión

- Registro de consultas anómalas.
- Detección de fallos de login repetidos.
- Limitación de conexiones por usuario.

8. Bastionado del servicio de correo

8.1. Controles básicos

- TLS en entrada y salida.
- SPF, DKIM y DMARC correctamente configurados, con DMARC en política quarantine o reject (en none solo informa).
- Filtrado de spam y malware.
- Limitación de relaying.

8.2. Separación de roles

Un servidor de correo no debe servir web, SSH o bases de datos en el mismo host.

9. Control de puertos y exposición

Cada servicio debe escucharse solo en:

- El puerto mínimo necesario.
- La interfaz adecuada (localhost cuando sea interno).
- La red correcta (segmentos específicos).

No se permite “0.0.0.0” en servicios internos.

Para ver qué está escuchando y dónde, en Linux se usa `sudo ss -tulpn` (sustituye al antiguo `netstat`) y en Windows `Get-NetTCPConnection -State Listen`.

10. Monitorización de servicios

Elementos clave

- Registro de logs en **otro servidor**.
- Alertas por comportamiento anormal.
- Métricas: uso de CPU, memoria, conexiones, fallos.
- Detección de cambios en archivos de configuración.

La supervisión continua es imprescindible cuando los servicios están en producción.

11. Hardening transversal

Políticas comunes

- Actualizaciones frecuentes.
- Eliminación de versiones legacy.
- Control de dependencias.
- Uso de contenedores o entornos aislados cuando sea posible.

Para ampliar

- Generador de configuraciones TLS de Mozilla (perfiles moderno, intermedio y antiguo).
- CIS Benchmarks de Nginx, Apache, MySQL, PostgreSQL y SQL Server.
- OWASP Secure Headers Project.
- Guías CCN-STIC sobre servicios (correo, DNS, servidores web).